

Annexe 1 – Catalogue Vulhub par classe de vulnérabilité

DOCUMENT

Catalogue Vulhub

PROMOTION

Master 1

Sommaire

Annexe 1 — Catalogue Vulhub par classe de vulnérabilité	3
1. CMS et sites web publics — RCE applicative	3
2. Portails, extranets, applications métier — upload / désérialisation / injection de code	4
3. Injection SQL	5
4. Lecture de fichier arbitraire — LFI, traversal, divulgation	5
5. SSRF et XXE	6
6. Partages et transfert de fichiers	6
7. Bases de données, caches, stockage	7
8. Recherche, observabilité, décisionnel	7
9. Chaîne de développement — SCM, CI, artefacts, conteneurs	8
10. Supervision et administration	8
11. Équipements, systèmes embarqués, services réseau	9
12. Messagerie et collaboration	9
13. Méthode de validation d'un service vulnérable	10
14. Pièges fréquents	10

Annexe 1 — Catalogue Vulhub par classe de vulnérabilité

Liste établie à partir du dépôt **vulhub/vulhub** (branche `master`, relevé du 4 septembre 2026 — 329 environnements). Chaque entrée correspond à un répertoire réel du dépôt :
`git clone https://github.com/vulhub/vulhub && cd vulhub/<chemin> && docker compose up -d`

Comment l'utiliser : votre CDC décrit des services métier, pas des vulnérabilités. C'est à vous de décider quels services vous rendez vulnérables et avec quoi. Ce catalogue classe les environnements Vulhub par **type de service** et par **type d'exploitation**, pour vous aider à choisir des briques cohérentes avec le besoin métier du CDC. Toute entrée du dépôt Vulhub est utilisable, y compris celles absentes de ce catalogue. Colonnes : **FS** = l'exploitation donne-t-elle un accès au système de fichiers ? **Diff.** = ★ facile · ★★ moyen · ★★★ difficile (dépendances externes, chaîne longue).

1. CMS et sites web publics — RCE applicative

Chemin Vulhub	Produit	Type	FS	Diff.	Notes d'intégration
drupal/ CVE-2018-7600	Drupal 7/8	RCE non authentifiée (Drupalgeddon2)	Oui	★	Le grand classique. Habillez le site aux couleurs de l'entreprise.
drupal/ CVE-2018-7602	Drupal	RCE authentifiée	Oui	★★	Nécessite un compte : bon pour un N2.
drupal/ CVE-2019-6339	Drupal 8	RCE (désérialisation phar)	Oui	★★	
drupal/ CVE-2014-3704	Drupal 7	Injection SQL pré-auth	Oui	★★	Aussi utilisable en classe « SQLi ».
joomla/ CVE-2015-8562	Joomla	RCE non authentifiée	Oui	★★	
joomla/ CVE-2017-8917	Joomla	Injection SQL	Partiel	★★	Donne des jetons de session admin → puis RCE.
joomla/ CVE-2023-23752	Joomla 4	Contrôle d'accès cassé → credentials	Partiel	★	Excellent point de départ de chaîne.
wordpress/ pwnscriptum	WordPress	RCE via réinitialisation de mot de passe	Oui	★★	
wordpress/ CVE-2026-63030	WordPress	vulnérabilité récente	—	★★	Vérifier le README du répertoire.
thinkphp/5-rce, thinkphp/5.0.23-rce	ThinkPHP	RCE non authentifiée	Oui	★	Idéal pour simuler un applicatif métier PHP legacy .
php/8.1-backdoor	PHP	porte dérobée dans l'interpréteur	Oui	★	Réaliste pour un hébergeur compromis.

2. Portails, extranets, applications métier — upload / désérialisation / injection de code

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
tomcat/ CVE-2017-12615	Tomcat	PUT → dépôt de JSP (webshell)	Oui	★	Le plus simple des webshells.
tomcat/tomcat8	Tomcat	mot de passe faible du Manager → déploiement WAR	Oui	★	Parfait pour un « portail interne déployé à l'arrache ».
tomcat/ CVE-2025-24813	Tomcat	écriture de session → RCE	Oui	★★	
weblogic/ CVE-2017-10271	WebLogic	RCE (XMLDecoder)	Oui	★★	Lourd (≈2 Go RAM).
weblogic/ CVE-2018-2894	WebLogic	upload de fichier arbitraire	Oui	★★	
weblogic/ weak_password	WebLogic	credentials faibles → déploiement	Oui	★	
jboss/ CVE-2017-12149	JBoss	désérialisation Java	Oui	★★	
struts2/s2-045 , s2-046 , s2-048 , s2-057 , s2-061 , s2-066	Struts2	injection OGNL → RCE	Oui	★ à ★★	Idéal pour un extranet fournisseurs ancien.
spring/ CVE-2022-22965	Spring (Spring4Shell)	RCE → webshell	Oui	★★	Nécessite Tomcat en WAR.
spring/ CVE-2022-22947	Spring Cloud Gateway	injection SpEL → RCE	Oui	★★	Bon pour une API/ passerelle .
spring/ CVE-2022-22963	Spring Cloud Function	injection SpEL → RCE	Oui	★	
shiro/ CVE-2016-4437	Apache Shiro	désérialisation via cookie rememberMe	Oui	★★	
fastjson/1.2.24- , rce 1.2.47-rce	Fastjson	désérialisation JSON	Oui	★★★	Nécessite un serveur LDAP/RMI attaquant.
log4j/ CVE-2021-44228	Log4j (Log4Shell)	injection JNDI → RCE	Oui	★★	Très pédagogique côté détection.
laravel/ CVE-2021-3129	Laravel + Ignition	RCE	Oui	★★	
ofbiz/ CVE-2020-9496 , CVE-2023-51467 , CVE-2024-38856	Apache OFBiz	ERP — RCE	Oui	★★	Le meilleur choix pour simuler un vrai ERP.
apereo-cas/4.1-rce	CAS	RCE (portail d'authentification)	Oui	★★	Réaliste pour un SSO universitaire.

3. Injection SQL

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
drupal/ CVE-2014-3704	Drupal 7	SQLi pré-auth	Oui	★★	
joomla/ CVE-2017-8917	Joomla	SQLi	Partiel	★★	
thinkphp/in- sqlinjection	ThinkPHP	SQLi	Partiel	★	Applicatif métier PHP.
zabbix/ CVE-2016-10134	Zabbix	SQLi (supervision)	Partiel	★★	
django/ CVE-2019-14234	Django	SQLi (JSONField)	Partiel	★★	
django/ CVE-2021-35042	Django	SQLi (order_by)	Partiel	★★	
yapi/mongodb-inj	YApi	injection NoSQL	Partiel	★★	Pour un SI orienté données.

⚠ Une SQLi ne donne pas d'accès FS par défaut. Pour respecter l'exigence « exploitation avec accès au FS » du socle, prévoyez soit INTO OUTFILE (MySQL avec `secure_file_priv` désactivé), soit un flag stocké en base (table `flags`), soit un rebond vers un autre service via les credentials extraits.

4. Lecture de fichier arbitraire — LFI, traversal, divulgation

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
php/inclusion	PHP	LFI classique	Oui	★	Le cas d'école pour <code>?file=../../etc/passwd</code>
httpd/ CVE-2021-41773 CVE-2021-42013	Apache httpd	path traversal (→ RCE si CGI)	Oui	★	
nginx/insecure- configuration	nginx	mauvaise configuration (alias off-by-slash)	Oui	★	Parfait pour un reverse proxy mal configuré.
grafana/ CVE-2021-43798	Grafana	lecture de fichier arbitraire	Oui	★	Idéal pour la supervision.
confluence/ CVE-2019-3396	Confluence	traversal → RCE	Oui	★★	Wiki interne.
kibana/ CVE-2018-17246	Kibana	LFI → RCE	Oui	★★	
solr/Remote- Streaming-Fileread	Solr	lecture de fichier	Oui	★★	
elasticsearch/ CVE-2015-5531	Elasticsearch	directory traversal	Oui	★★	

phpmyadmin/ CVE-2018-12613	phpMyAdmin	LFI → RCE	Oui	★	Très crédible sur un hébergeur.
jetty/ CVE-2021-28164 CVE-2021-34429	Jetty	divulgence de WEB-INF	Partiel	★★	Fuite de configuration et de credentials.
nexus/ CVE-2024-4956	Nexus	path traversal	Oui	★	Dépôt d'artefacts.
minio/ CVE-2023-28432	MinIO	divulgence de credentials	Partiel	★	Stockage objet.
jenkins/ CVE-2024-23897	Jenkins	lecture de fichier arbitraire	Oui	★	

5. SSRF et XXE

Chemin Vulhub	Produit	Type	Diff.	Notes
weblogic/ssrf	WebLogic	SSRF → pivot Redis interne	★★	Chaîne SSRF→Redis→RCE, très pédagogique.
grafana/admin-ssrf	Grafana	SSRF	★	
solr/ CVE-2017-12629-XXE	Solr	XXE	★★	
php/php_xxe	PHP	XXE	★	

6. Partages et transfert de fichiers

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
samba/ CVE-2017-7494	Samba (SambaCry)	RCE via partage inscriptible	Oui	★★	Le choix par défaut pour un serveur de fichiers.
rsync/common	rsync	module anonyme en lecture/écriture	Oui	★	Idéal pour un serveur de sauvegarde .
minio/ CVE-2023-28432	MinIO	stockage objet	Partiel	★	

FTP : le dépôt Vulhub ne fournit pas d'environnement FTP vulnérable. Vous pouvez déployer un serveur FTP standard (vsftpd, pure-ftpd) **mal configuré** (accès anonyme en écriture, credentials faibles) — il compte comme *service* du catalogue et comme mauvaise configuration réaliste, mais **pas** dans le quota de services vulnérables Vulhub. Pour ce quota, utilisez `rsync/common` ou `samba/CVE-2017-7494`.

7. Bases de données, caches, stockage

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
redis/4-unacc	Redis	absence d'authentification → RCE (cron, clé SSH)	Oui	★	Le pivot idéal après une SSRF.
redis/ CVE-2022-0543	Redis	évasion du bac à sable Lua → RCE	Oui	★★	
mysql/ CVE-2012-2122	MySQL	contournement d'authentification	Partiel	★★	Base legacy crédible.
postgres/ CVE-2019-9193	PostgreSQL	COPY FROM PROGRAM → RCE	Oui	★★	Nécessite des credentials (bon N3).
postgres/ CVE-2018-1058	PostgreSQL	élévation via public schema	Partiel	★★	
couchdb/ CVE-2017-12635 CVE-2017-12636	CouchDB	élévation puis RCE	Oui	★★	
mongo-express/ CVE-2019-10758	Mongo Express	RCE sur l'interface d'administration	Oui	★	Base NoSQL + interface en une seule brique.
influxdb/ CVE-2019-20933	InfluxDB	contournement d'authentification JWT	Partiel	★	Historian industriel ou métrologie.
opentsdb/ CVE-2020-35476 CVE-2023-25826	OpenTSDB	RCE	Oui	★★	Autre choix d'historian.
celery/ celery3_redis_unauth	Celery + Redis	RCE via file de tâches	Oui	★★	

8. Recherche, observabilité, décisionnel

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
elasticsearch/ CVE-2014-3120 CVE-2015-1427	Elasticsearch	RCE par script	Oui	★	
kibana/ CVE-2019-7609	Kibana	pollution de prototype → RCE	Oui	★★	
solr/CVE-2019-17558	Solr	RCE (template Velocity)	Oui	★	Moteur de recherche produits d'un e-commerce.
solr/ CVE-2017-12629-RCE	Solr	RCE	Oui	★★	
metabase/ CVE-2023-38646	Metabase	RCE pré-authentifiée	Oui	★	Décisionnel / reporting.
grafana/ CVE-2024-9264	Grafana	RCE (expressions SQL)	Oui	★★	

apache-druid/ CVE-2021-25646	Druid	RCE	Oui	★★
---------------------------------	-------	-----	-----	----

9. Chaîne de développement — SCM, CI, artefacts, conteneurs

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
gitlab/ CVE-2021-22205	GitLab	RCE non authentifiée (ExifTool)	Oui	★★	Le pivot roi d'un SI d'éditeur.
gitea/1.4-rce	Gitea	RCE	Oui	★★	Alternative légère à GitLab.
gogs/ CVE-2018-18925	Gogs	RCE (désérialisation de session)	Oui	★★	
jenkins/ CVE-2017-1000353 CVE-2018-1000861	Jenkins	RCE	Oui	★★	Serveur de build / déploiement.
jenkins/ CVE-2024-23897	Jenkins	lecture de fichier → credentials	Oui	★	Bon premier pas avant la RCE.
nexus/ CVE-2019-7238 CVE-2020-10199	Nexus Repository	RCE	Oui	★★	Dépôt d'artefacts.
docker/ unauthorized-rce	Docker	démon exposé sur 2375 → RCE hôte	Oui	★	Attention : très puissant. Réservez-le à un N3.
xxl-job/unacc	XXL-JOB	ordonnanceur sans authentification → RCE	Oui	★	Orchestrateur de traitements batch.
airflow/ CVE-2020-11978 CVE-2020-17526	Airflow	RCE / contournement d'authentification	Oui	★★	Pipelines de données (recherche, retail).
saltstack/ CVE-2020-11651 CVE-2020-11652	SaltStack	contournement d'authentification → RCE sur les minions	Oui	★★	Outil d'infogérance : compromission de masse.
nacos/ CVE-2021-29441	Nacos	contournement d'authentification	Partiel	★	Registre de configuration microservices.

10. Supervision et administration

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
zabbix/ CVE-2020-11800	Zabbix	RCE	Oui	★★	
zabbix/ CVE-2016-10134	Zabbix	SQLi	Partiel	★★	

cacti/ CVE-2022-46169	Cacti	injection de commande non authentifiée	Oui	★	Excellent choix « supervision d’une collectivité ».
cacti/ CVE-2023-39361	Cacti	SQLi	Partiel	★★	
grafana/ CVE-2021-43798	Grafana	lecture de fichier	Oui	★	
supervisor/ CVE-2017-11610	Supervisord	RCE via XML-RPC	Oui	★★	
lpanel/ CVE-2024-39907	lPanel	panneau d’administration	Oui	★★	Panel d’hébergement mutualisé.

11. Équipements, systèmes embarqués, services réseau

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
goahead/ CVE-2017-17562	GoAhead	RCE — serveur web embarqué	Oui	★★	LE choix pour une caméra IP / un NVR / une IHM industrielle.
goahead/ CVE-2021-42342	GoAhead	RCE	Oui	★★	
appweb/ CVE-2018-8715	AppWeb	contournement d’authentification	Partiel	★	Équipement embarqué.
uwsgi/unacc , uwsgi/ CVE-2018-7490	uWSGI	RCE / traversal	Oui	★★	
libssh/ CVE-2018-10933	libssh	contournement d’authentification SSH	Oui	★	Passerelle de maintenance ou équipement admin.
openssh/ CVE-2018-15473	OpenSSH	énumération d’utilisateurs	Partiel	★	Reconnaissance, à combinaison avec un mot de passe faible.
openssl/ CVE-2014-0160	OpenSSL (Heartbleed)	fuite mémoire	Partiel	★	Legacy crédible sur un équipement ancien.

12. Messagerie et collaboration

Chemin Vulhub	Produit	Type	FS	Diff.	Notes
openfire/ CVE-2023-32315	Openfire	traversal → prise de contrôle → RCE	Oui	★★	Serveur de messagerie interne.
opensmtpd/ CVE-2020-7247	OpenSMTPD	RCE	Oui	★★	Relais de messagerie.
phpmailer/ CVE-2017-5223	PHPMailer	LFI	Oui	★★	

confluence/ CVE-2022-26134, CVE-2023-22515, CVE-2023-22527	Confluence	RCE / élévation	Oui	★★	Wiki interne – pivot majeur.
jira/CVE-2019-11581	Jira	injection de template → RCE	Oui	★★	Ticketing interne.
activemq/ CVE-2016-3088	ActiveMQ	upload → RCE	Oui	★	File de messages.
activemq/ CVE-2023-46604	ActiveMQ	RCE (OpenWire)	Oui	★★	
jupyter/notebook-rce	Jupyter Notebook	terminal sans authentification → RCE	Oui	★	Notebooks de recherche.

13. Méthode de validation d'un service vulnérable

Pour **chaque** service vulnérable, avant la fin de la phase de build :

1. `git clone https://github.com/vulhub/vulhub` puis `cd <chemin>` et lire le `README.md` du répertoire — il contient l'exploit de référence.
2. Analyser `docker-compose.yml` et `Dockerfile` : image, ports publiés, volumes, variables d'environnement.
3. Habiller le service : nom de domaine, thème, contenu métier, comptes, bannière. **Ne jamais** toucher au composant vulnérable lui-même.
4. Rejouer l'exploit **depuis une machine du réseau attaquant** (pas depuis l'hôte Docker).
5. Vérifier le type d'accès obtenu :
 - `shell` → `id`, `ls /`, `ls /root`
 - lecture de fichier → `/etc/passwd`, fichier de configuration applicatif
 - base de données → `SHOW DATABASES`, contenu de la table `flags`
6. Déposer le flag à l'emplacement imposé par le CDC, puis **rejouer l'exploit** pour confirmer qu'il est bien atteignable par ce chemin — et **uniquement** par ce chemin.
7. Copier la commande et sa sortie dans le document pédagogique.

14. Pièges fréquents

- **Tout tourne sur un seul hôte Docker** : la RAM est la ressource critique. Deux ou trois services Java lourds (WebLogic, Confluence, Jira, Nexus) suffisent à saturer l'hôte et à rendre le SI indisponible pendant l'exercice. Préférez les équivalents légers et posez des `mem_limit`.
- **Rattacher chaque conteneur au bon réseau Docker** : un environnement Vulhub définit son propre réseau par défaut. Remplacez-le par le réseau de la zone du CDC (`net-dmz`, `net-srv`, ...) et ne publiez de `ports` que pour les services exposés.
- **Le service tombe tout seul** : nombreuses images Vulhub sont anciennes et redémarrent en boucle. Ajoutez `restart: always` et vérifiez `docker compose ps` chaque matin.
- **Ports en conflit** : deux environnements Vulhub utilisent souvent le port 8080. Publiez chacun sur un port distinct et faites la traduction dans le reverse proxy.

- **Exploit qui nécessite une infrastructure attaquante** (`fastjson` , `log4j`) : vérifiez que le réseau de l'exercice permet la connexion sortante du service vers l'attaquant, sinon l'exploitation est impossible et la vulnérabilité est considérée comme cassée.
- **Docker socket monté** : ne montez jamais `/var/run/docker.sock` dans un conteneur vulnérable, sauf si c'est justement le N3 recherché — sinon toute la maquette tombe d'un coup.
- **Flag trouvable sans exploitation** : vérifiez que le flag n'est pas dans un répertoire web listable, un dépôt Git public ou une image Docker publique.